


**College of Computing**

**Cybersecurity Department**

Course: Cybersecurity Operations – SEC3106

# Cybersecurity Program Project

*MediCare Hospital*

**Submitted by:**

Sarah Ibrahim Alsulami [redacted]
Reemas [redacted]
Reham [redacted]
Ghadah [redacted]

**Instructor:** Sabreen [redacted]

# Contents


**1 Introduction to the Organization** **3**

**2 Asset Identification and Classification** **4**

2.1 Asset Identification . . . . . 4

2.2 Asset Classification . . . . . 5

**3 Security Policies** **7**

3.1 Access Control Policy . . . . . 7

3.2 Data Classification Policy . . . . . 10

3.3 Patch Management Policy . . . . . 12

3.4 Incident Response Policy (ECC: Resilience) . . . . . 16

3.5 Business Continuity Policy and Disaster Recovery (BC/DR) Policy (ECC: Resilience) . . . . . 20

**4 Mapping Business Objectives to Security Goals** **23**

**5 Security Program Design** **26**

5.1 Program goals . . . . . 26

5.2 Governance Structure for Cybersecurity . . . . . 26

5.2.1 CISO Role . . . . . 26

5.3 NIST Cybersecurity Framework Alignment . . . . . 30

5.3.1 Purpose . . . . . 30

5.3.2 Objectives . . . . . 30

5.3.3 Alignment of Functions with the NIST CSF . . . . . 31

5.4 Implementation Strategy . . . . . 32

5.4.1 Technical Security and Training . . . . . 32

5.4.2 Physical Security and Safety . . . . . 35

5.5 Risk Management and Assessment . . . . . 38

5.5.1 Scope and Classified Assets (The Attack Surface) . . . . . 38

5.5.2 Threat Agents and Motivation . . . . . 38
5.5.3 Critical Vulnerabilities and Entry Points . . . . . 39
5.5.4 Risk Assessment Matrix . . . . . 41
5.6 Business Continuity and Disaster Recovery Plan . . . . . 42
5.6.1 Business Impact Analysis (BIA) . . . . . 43
5.6.2 Backup strategies . . . . . 43
5.6.3 Disaster Recovery Procedures . . . . . 44
5.7 Evaluation Framework . . . . . 46

**6 Recommendations and Future Improvements** **48**

**7 Conclusion** **51**

# Chapter 1

# Introduction to the Organization

MediCare Hospital is a healthcare institution that delivers essential medical services to a wide range of patients. MediCare Hospitals are medium to large in size and consist of many clinical and administrative departments, which are staffed by medical, technical and support personnel. Being a modern hospital in a rapidly changing digital world, the hospital's medical expertise, administrative systems and linked information technology are the basis of its daily operations. It continues to provide sustained health care, emergency, inpatient and outpatient, diagnostic services, and other specialized medical departments, in line with its vision and mission. These systems assist the hospital in managing patient data, internal communications within the hospital, and scheduling and other operations. These systems make hospital cybersecurity a priority, due to the extremely sensitive nature of the data hospitals keep and the reality that even a minor data breach could have serious consequences for a patient. Recognizing the frequency of data breaches, data exfiltration, intrusion, service disruption, and attacks in the cybersecurity landscape of the healthcare sector, MediCare Hospital considers a formal and thorough information security program as an essential element of safeguarding the confidentiality, integrity, and availability of its information assets and supporting the safe and reliable delivery of patient care.

# Chapter 2

# Asset Identification and Classification

## 2.1 Asset Identification

Asset identification is the process of identifying all valuable resources in the hospital, both tangible and intangible, that needs to be protected. These assets include people, information, software, hardware, and physical facilities. MediCare Hospital depends on a wide range of information and physical assets to deliver healthcare services effectively. These assets can be categorized as follows:

### Information Assets

Information assets are the critical data and records that the hospital relies on to provide effective healthcare services. These assets include patient records such as Electronic Health Records (EHR), medical histories, and lab results; financial data including billing information and insurance claims; administrative data such as staff records, schedules, and internal communications; and research data comprising clinical trials and study results. Protecting these information assets properly helps keep hospital data confidential, accurate, and available when needed.

### Hardware Assets

Hardware assets include all physical devices that the hospital uses to deliver healthcare services and maintain operations. These consist of medical equipment such as magnetic resonance imaging (MRI) machines, X-ray machines, ventilators, and dialysis machines; IT equipment including servers, computers, networking devices, and printers; and mobile devices such as tablets, laptops, and mobile workstations. Management and maintenance of these

hardware assets ensure reliable and continuous patient care.

### Software Assets

Software assets consist of the applications and systems that support hospital operations and healthcare delivery. These include Hospital Management Systems (HMS) for scheduling, billing, and patient management; Laboratory Information Systems (LIS) for managing lab data; Radiology Information Systems (RIS) for handling radiology workflows; and Clinical Decision Support Systems (CDSS) that assist clinicians in making informed medical decisions. Effective management and security of these software assets are essential to ensure reliable operations and protect sensitive hospital data.

### Physical Assets

Physical assets are tangible resources that support hospital operations and ensure the safety of patients and staff. These include buildings and rooms such as operating theaters, laboratories, patient rooms, and data centers, as well as security devices such as CCTV systems, access control systems, and fire alarms. These physical assets also need to be maintained and protected to ensure a safe and reliable healthcare environment.

### Human Assets

Human assets are all personnel involved in hospital operations and the delivery of healthcare services. This includes doctors, nurses, psychologists, along with social workers. Administrative staff and information technology staff, laboratory technicians, contractors and vendors who provide essential support and services. Maintain human assets effectively is important to maintaining hospitals and providing high quality patient care, and overall organizational security.

## 2.2 Asset Classification

To effectively protect the hospital's valuable resources, it is essential to identify and classify all assets according to their sensitivity and importance. This classification helps prioritize security measures and ensures that information, physical resources, and personnel are safeguarded appropriately. The table below shows the main assets of MediCare Hospital, their classification levels, and the justification for each category.

| **Asset** | **Classification** | **Justification** |
|---|---|---|
| Patient Information | Highly Sensitive | Contains personal and medical data of patients; unauthorized access can harm patients and violate privacy regulations. |
| Financial Records | Highly Sensitive | Includes billing and insurance details; breaches can cause financial loss and legal issues. |
| Staff Records | Sensitive | Contains personal details of hospital staff; disclosure can lead to privacy issues and operational disruptions. |
| Research Data | Sensitive | Confidential data critical to studies; leakage may compromise intellectual property and research integrity. |
| Medical Equipment | Critical | Essential for diagnosis and treatment; malfunction or tampering can affect patient care. |
| IT Infrastructure | Highly Critical | Includes servers, networking devices, and storage; a compromise can disrupt operations and patient care. |
| Hospital Software Systems | Highly Critical | Supports scheduling, billing, patient management, lab and clinical workflows; downtime or breaches directly impact operations. |
| Physical Facilities | Critical | Includes patient rooms, operating theaters, and laboratories; must be safe and functional for patient care. |
| Security Systems | Sensitive | Includes surveillance, access control, and alarms; compromise can lead to safety and security risks. |
| Human Resources | Highly Critical | Includes doctors, nurses, clinical and administrative staff; their availability and competence directly impact patient care. |
| Contractors & Vendors | Sensitive | Provide support or services with limited access; improper management can create security risks. |

Table 2.1: Asset Classification for MediCare Hospital

# Chapter 3

# Security Policies

## 3.1 Access Control Policy

### Purpose

The purpose of this Access Control Policy is to ensure that access to MediCare Hospital's information systems, medical devices, and physical facilities is granted only to authorized individuals based on their job responsibilities. This policy protects the confidentiality, integrity, and availability of Electronic Protected Health Information (ePHI) and supports compliance with healthcare regulations.

### Scope

This policy applies to:

- All hospital employees, including clinical, administrative, and technical staff.
- Contractors, vendors, students, and temporary workers.
- All IT systems, networks, applications, medical devices, and physical access-controlled areas.
- Any access to patient information, staff data, or hospital infrastructure.

### Policy Principles

#### Least Privilege

All users shall be granted the minimum access required to perform their job duties. No user may access systems or data beyond what is necessary for their role.

### Role-Based Access Control (RBAC)

Access to hospital systems, including EHR, billing systems, laboratory systems, and network services, must follow RBAC. Permissions are determined strictly by job title and departmental responsibilities.

### Authentication Requirements

- All users must authenticate using a unique username and password.
- Multi-Factor Authentication (MFA) is required for:
  - Administrative and privileged accounts,
  - Remote access (VPN, cloud systems),
  - Systems containing ePHI.
- Default or shared passwords are not allowed.

### Authorization

Access rights must be approved by the Data Owner and validated by the IT Security Team before being assigned.

## Physical Access Control

- Restricted areas (Data Center, Pharmacy, NICU, Operating Rooms, Laboratories) require badge access and biometric verification.
- Tailgating and piggybacking are prohibited. Staff must challenge unknown individuals.
- Lost or stolen access cards must be reported immediately and deactivated.

## Logical Access Control

- Unique User IDs must be used to maintain accountability and audit trails.
- Emergency "Break-Glass" access is permitted only during critical medical scenarios and must be monitored and logged.
- Workstations and systems must auto-lock after a defined period of inactivity.

## Access Review and Monitoring

- Access rights must be reviewed quarterly by the Department Head and IT Security Team.
- Audit logs must be kept for all access to ePHI and critical systems.
- Suspicious access patterns, repeated login failures, or privilege escalation attempts must trigger security alerts.

## Onboarding and Offboarding

### Onboarding

- New users receive access only after completing mandatory cybersecurity and HIPAA training.
- Accounts are provisioned according to the RBAC matrix.

### Offboarding

- Access for terminated or transferred staff must be revoked immediately.
- Physical badges, keys, laptops, and mobile devices must be returned.

## Remote Access

- Remote connections must use encrypted channels (VPN with MFA).
- Access to ePHI from personal devices is prohibited unless managed through Mobile Device Management (MDM).

## Vendor and Contractor Access

- Temporary access must be time-limited, monitored, and restricted to specific tasks.
- Vendors may access systems only under supervision when working with medical devices or IT systems.
- All third parties must sign confidentiality and compliance agreements.

### Enforcement

Failure to comply with this policy may result in disciplinary action, termination of employment, revocation of system privileges, or legal consequences.

### Review and Updates

This policy shall be reviewed annually or after major system changes, regulatory updates, or significant security incidents.

## 3.2 Data Classification Policy

### Purpose

The purpose of this Data Classification Policy is to ensure the protection, proper handling, and governance of all information assets at MediCare Hospital. It aims to safeguard sensitive data, support regulatory compliance, and maintain confidentiality, integrity, and availability.

### Scope

This policy applies to all forms of hospital information, including digital, paper-based, and multimedia data concerning patients, staff, financial matters, and hospital operations. It covers any data generated, stored, transmitted, or processed inside or outside MediCare Hospital.

### Key Principles

- Ensure Confidentiality, Integrity, and Availability (CIA) of all data.
- Enforce the Principle of Least Privilege to limit access to authorized personnel only.
- Ensure separation of duties and assign clear accountability for all data management activities.
- Classify data according to sensitivity to determine appropriate security controls.

### Data Classification Levels

MediCare Hospital adopts a four-level data classification model: Public, Internal, Confidential, and Protected. Each level defines the sensitivity of the data and the required security

controls [1]. Figure 5.2 illustrates these four levels along with their associated sensitivity and security requirements.

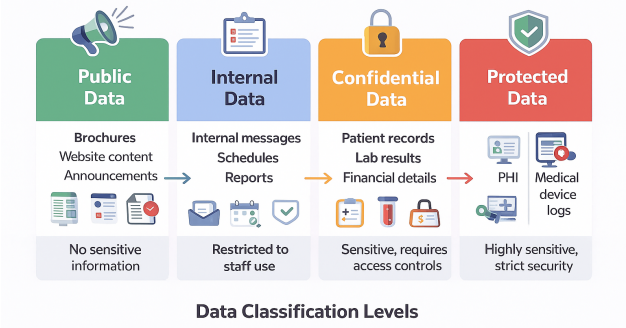



Figure 3.1: Data classification levels.

### Public Data

Public data includes information approved for external release and intended for unrestricted access by the general public. This category contains only non-sensitive materials and does not include any patient information or content that could compromise privacy. Disclosure poses no risk to hospital operations or patient confidentiality. **Examples:** brochures, general announcements, website content, publicly available educational materials. **Controls:** Accuracy and integrity must be maintained; encryption is not required.

### Internal Data

Internal data includes everyday hospital information meant to remain within MediCare Hospital. Unauthorized sharing may disrupt operations or cause confusion. **Examples:** internal messages, staff schedules, simple reports, administrative documents. **Controls:** Access restricted to authorized staff; basic monitoring recommended; encryption not mandatory.

### Confidential Data

Confidential data includes sensitive information that, if accessed or disclosed without authorization, could negatively impact patients, staff, or hospital operations. **Examples:** medical records, laboratory results, staff information, authentication logs, IT system configurations and standard authentication logs. **Controls:** Strict access controls, encryption in transit and at rest, continuous monitoring for regulatory compliance.

#### Protected Data

Protected data represents the highest classification level, whose compromise could lead to severe legal, operational, or patient-safety risks. **Examples:** personal health information (PHI), cryptographic keys, privileged credentials, medical device configuration data, security incident documentation,disaster recovery plans, incident response procedures. **Controls:** Multi-factor authentication, role-based access, secured storage environments, comprehensive audit trails.

### Roles Responsibilities

- **Staff:** Comply with classification and avoid unauthorized disclosure.
- **Data Owner:** Defines classification levels, approves access, and oversees data usage.
- **Data Custodian:** Implements security controls, monitors access, and maintains data integrity.
- **Hospital Management:** Ensures compliance, conducts audits, and reviews policies periodically.
- **Training & Awareness:** Staff must understand data classification levels, hospital policies, and basic security practices to prevent accidental disclosure [2].

### Review and Update

This policy shall be reviewed at least annually or when new data types are introduced. Classification levels and controls shall be updated based on emerging risks, regulatory requirements, or operational changes.

## 3.3 Patch Management Policy

### Purpose

The Patch Management Policy at MediCare Hospital ensures that all clinical, administrative, and IT systems remain secure, stable, and protected against known vulnerabilities [3]. The purpose of this policy is to define a structured patching process that minimizes risks to patient data, medical devices, and hospital operations, ensures compliance with national and international standards, and maintains the Confidentiality, Integrity, and Availability (CIA) of hospital information systems.

## Scope

This policy applies to all hospital IT systems, applications, network devices, and medical devices managed by MediCare Hospital. It covers all environments including production, test, and development systems, and applies to all employees and departments involved in patching, testing, deployment, or oversight of hospital IT infrastructure. All software patches including security updates, system hotfixes, firmware updates, and third-party application updates must follow the procedures defined in this policy.

## Policy Overview

All patches are tested in a staging environment prior to production deployment and must be fully documented, including system affected, patch details, deployment date/time, risk level, and responsible personnel. The patching cycle, responsibilities, and timelines are structured to maintain hospital operations and patient safety.

## Patch Cycles

MediCare Hospital follows a structured, recurring patching schedule:

- **Critical Security Patches:** Address vulnerabilities directly affecting patient data, ICU/ER systems, surgical systems, or HIS. Evaluated within 24 hours and deployed rapidly.
- **High-Priority Patches:** Address high-risk vulnerabilities not yet exploited but requiring prompt testing and deployment.
- **Routine OS & Application Patches:** Regular updates applied in scheduled maintenance windows.
- **Medical Device Firmware Updates:** Updates for MRI, ventilators, infusion pumps, and monitors, coordinated with vendors and biomedical engineering to avoid clinical disruption.
- **Emergency Patching:** Applied immediately for vulnerabilities posing imminent risk to hospital operations or patient safety.
- **Third-Party Applications:** EHR modules, antivirus, billing, and vendor software updates.
- **Network Equipment:** Switches, routers, firewalls, and controllers updated quarterly or per vendor advisories.

## Responsibilities

**Cybersecurity / IT Security Team:** Monitors vulnerability feeds, evaluates severity, prioritizes updates, coordinates schedules, and ensures compliance with standards.

**IT / System Administrators:** Test patches, deploy in production, execute rollback procedures if needed, and document all activities.

**Biomedical Engineering:** Manage firmware updates for medical devices, verify safety, and ensure regulatory compliance.

**Department Heads / Unit Managers:** Ensure systems are available for patching and communicate operational impacts.

**Quality & Compliance Unit:** Audit patching processes, maintain records, and ensure regulatory compliance.

## Timelines & Compliance

All patching activities at MediCare Hospital must be tested in a staging environment before deployment to production. Patch deployment must not disrupt critical hospital services unless explicitly approved by the IT Director.

Each patching activity must be documented, including system, patch details, deployment date/time, risk level, and responsible personnel. Patches are applied according to their defined timelines, as illustrated in Table 3.1: Critical, High-Priority, Routine, Medical Device Firmware, Emergency, Third-Party Applications, or Network Equipment [3].

Monthly patching reports are reviewed by IT Security and the Compliance Unit to verify adherence, identify gaps, and plan remediation actions.

**Patch Management Timelines – MediCare Hospital**

Table 3.1: Patch Management Timelines at MediCare Hospital

| Patch Type | Description | Timeline | Responsible |
|---|---|---|---|
| Critical | Threatens patient data or critical systems (EHR, ICU/ER, authentication) | 72 hours | IT Security + SysAdmins |
| High-Priority | High-risk but not actively exploited vulnerabilities | 7 days | SysAdmins |
| Routine | OS and application updates applied in scheduled maintenance | Monthly | SysAdmins |
| Device Firmware | Updates for MRI, ventilators, pumps, monitors; coordinated with vendors | Per vendor schedule | Biomedical Engineering |
| Emergency | Immediate patch for imminent risk; may occur outside normal windows | Same day | IT Director + Security Team |
| Third-Party Apps | EHR modules, antivirus, billing, and other vendor software | 14 days | SysAdmins |
| Network Equipment | Switches, firewalls, routers, controllers; applied quarterly or per vendor advisory | Quarterly | Network Team |

## Update and Review

The **Cybersecurity / IT Security Team** must review the Patch Management Policy at least once a year, or whenever there are changes to the policy, organizational procedures, or relevant legal and regulatory requirements [3]. This ensures the policy remains up-to-date, compliant, and effective. Any updates or revisions must be documented, approved by hospital management, and communicated to all relevant staff.

## 3.4 Incident Response Policy (ECC: Resilience)

### Purpose

To establish an organized approach to detect electronic incidents that may affect the confidentiality of medical data, integrity, availability, or disrupt healthcare information systems, and to respond to and recover from them. [4]

### Scope

Covers all electronic incidents affecting patient data, hospital operations, communication with staff and guardians, and access to medical information systems.

### Objectives

- Protect sensitive information and medical data.
- Minimize damages resulting from security incidents on workflow.
- Restore operations quickly and efficiently.

### Roles and Responsibilities

**Incident Response Team (IRT)**: Led by the Chief Information Officer (CIO) and the Cybersecurity Director, including:

- Head of Communications: Coordinating internal and external communications.
- Legal Affairs: Assessing legal implications of incident reporting and managing legal repercussions.
- System Staff: Providing technical support and analyzing affected systems.

### Policy Details

### A) Incident Classification

- **Critical**: Complete system failure or breach of sensitive data. (Immediate response within 1 hour)
- **High**: Significant impact on systems or data with recovery potential. (Response within 4 hours)

- **Medium**: Limited effect on operations, with readiness for recovery. (Response within 12 hours)
- **Low**: Minor incidents with no impact on workflow. (Response within 24 hours)
- **Example:** A critical incident may involve unauthorized access to patient records, requiring immediate containment and notification to affected individuals within the hour.

## B) Standard Lifecycle

### 1. Detection

- **Using monitoring tools:**
  - Implementing advanced systems to monitor suspicious activity, such as record management systems and network monitoring.
  - Utilizing big data analytics tools to analyze patterns and detect any unusual behavior in health information systems.
  - **Example:** Anomaly detection software identifies a sudden spike in access to certain patient files, triggering an alert to the IRT.
- **Immediate alerts:**
  - Setting up automatic warning alerts that are sent to the response team when any unusual activity is detected, such as unauthorized access attempts to patient records.
  - **Example:** If a staff member's account is accessed from an unusual location, the system sends an immediate alert to the IRT for further investigation.

### 2. Containment

- **Isolating Affected Systems:**
  - Disconnecting affected systems or devices (such as computers or servers) from the network to prevent the incident from spreading to other systems, such as medical information systems.
  - **Example:** In a situation where malware is detected on a workstation, the IT team immediately disconnects that workstation from the network to contain the threat.

- **Risk Assessment:**
  - Conducting a rapid assessment to determine the extent of the impact across different hospital systems and how to contain the incident with minimal disruption to healthcare services.
  - **Example:** After a suspected phishing attack, the IRT assesses which systems may have been affected and prioritizes containment efforts based on criticality.

**3. Eradication**

- **Root Cause Analysis:**
  - Assign a technical team to analyze the technical and administrative aspects of the incident, such as human error or software vulnerabilities.
  - **Example:** If the breach was due to a phishing email that was opened by an employee, the team will analyze the training provided to identify gaps in employee awareness.
- **Threat Removal:**
  - Implement steps to eradicate malware, such as using antivirus software and recovery tools, and ensure there are no vulnerabilities in the software used at the hospital.
  - **Example:** After removing malware from the affected systems, the IRT confirms that all software is patched and no backdoor access is left open.

**4. Recovery**

- **System and Data Recovery:**
  - Perform a system and data recovery process for affected systems using approved backups.
  - Restore systems to their normal state, ensuring the incident does not disrupt medical services.
  - **Example:** A hospital uses its last known good backup to restore electronic health records after a ransomware attack, allowing them to resume normal operations.
- **Safety Verification Tests:**
  - Conduct comprehensive tests on the restored systems to ensure they are functioning efficiently and to identify any potential issues before re-employment.

- **Example:** After recovery, the IT team performs multiple tests to ensure that all patient data is intact and that the systems are secure before going back online.

**5. Lessons Learned**

- **Incident Analysis:**
  - The relevant team will convene to conduct a comprehensive review of the incident, focusing on what happened, when it happened, how it was identified, and its impact on the hospital.
  - **Example:** In a post-incident meeting, the team identifies that the absence of multi-factor authentication contributed to the incident, suggesting its implementation for future prevention.
- **Policy Update:**
  - Based on the lessons learned, the hospital's safety policies and procedures will be updated to improve the effectiveness of future incident response.
  - The dynamics and lessons learned will be shared with all staff, and they will be trained on the planned steps to prevent similar incidents from occurring in the future.
  - **Example:** A new training module is developed for staff based on insights from the incident, emphasizing the importance of recognizing phishing emails.

## C) Evidence Preservation

- Retaining incident records and support tickets in accordance with legal documentation policies.
- Coordinating external reports with relevant authorities as needed.
- **Example:** All logs relating to the incident are archived and maintained for a minimum of five years, in line with regulatory requirements.

## D) Training and Awareness

- Conducting at least one practical annual training for all staff on how to handle electronic incidents.

- Organizing technical training for the IRT, such as simulating a ransomware attack on medical systems.
- **Example:** An annual training session includes a live simulation of a data breach scenario, allowing staff to practice their roles in real-time.

### Reporting and Communication

All staff must immediately report any electronic incident to the IRT. Providing clear guidance to employees on how to report incidents and escalation steps.
**Example:** A one-page quick reference guide is distributed to all employees detailing how to report incidents and the importance of timely communication in incident response.

## 3.5 Business Continuity Policy and Disaster Recovery (BC/DR) Policy (ECC: Resilience)

### Purpose

To ensure that the hospital can continue essential operations—such as patient care, medical record access, communication systems, and critical healthcare services—during and after disruptions, with clear recovery procedures and defined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) suitable for a healthcare environment. [5]

### Scope

Covers all critical processes, services, and systems essential for hospital operations, including but not limited to patient care systems, electronic health records, communication systems, laboratory systems, and administrative functions.

### Roles and Responsibilities

- **Chief Executive Officer (CEO)**: Policy sponsor ensuring overall support and resources.
- **Chief Information Officer (CIO)**: Leads Business Continuity Management (BCM) initiatives.
- **IT Manager**: Oversees Disaster Recovery (DR) procedures and execution.

- **Department Heads**: Responsible for process ownership, ensuring that departmental needs are incorporated into the BC/DR framework.

## Policy Statements

1. **Business Impact Analysis (BIA)**

    - Maintain a comprehensive BIA that identifies critical operations, assesses impact, and establishes RTO and RPO targets for all essential services.
    - Conduct an annual review of the BIA to ensure relevance and accuracy.
    - **Example:** If the patient registration system is identified as critical, the BIA may establish an RTO of 1 hour and an RPO of 15 minutes to minimize potential disruptions to patient admissions.

2. **Data Backup Procedures**

    - Implement daily incremental backups and weekly full backups for critical systems (e.g., electronic health records, patient billing, and pharmacy systems).
    - Secure backups must be stored offsite or in the cloud with encryption to protect against data breaches.
    - Conduct quarterly restore tests to verify the integrity and reliability of backup data.
    - **Example:** After a power outage, the hospital successfully retrieves patient billing information from a cloud-based backup taken 24 hours prior, demonstrating the effectiveness of the backup procedures.

3. **Recovery Runbooks**

    - Develop and maintain documented runbooks outlining the step-by-step recovery procedures for each critical system.
    - Ensure runbooks are accessible and regularly updated to reflect changes in technology or processes.
    - **Example:** A runbook for the laboratory information system might include specific commands to restart servers, re-establish network connections, and verify data integrity before resuming operations.

4. **Alternate Communication Channels**

- Establish alternate communication channels for staff and stakeholders during incidents, ensuring continuity of information flow.
- Test these channels regularly to ensure their effectiveness during an actual incident.
- **Example:** In the event of a network failure, the hospital may use SMS alerts to inform staff about critical updates and alternative communication methods for patient information.

5. **Integration with Incident Response**
    - Integrate BC/DR exercises with incident response plans and protocols.
    - Conduct regular training and exercises to evaluate the BC/DR effectiveness, ensuring lessons learned are tracked and improvements are implemented.
    - **Example:** During a simulated cyber-attack exercise, both the BC/DR team and incident response team work together to identify vulnerabilities and improve communication, enhancing overall organizational readiness.
6. **Continuous Improvement**
    - After each BC/DR exercise, conduct a review session to assess performance, identify gaps, and implement corrective actions.
    - Document findings and actions taken to improve the BC/DR plan continuously.
    - **Example:** Following a tabletop exercise, the team identifies that response times need improvement, resulting in updated training sessions and refined procedures to enhance readiness.

## High-Level Continuity Rules

- Essential services must remain operational during disruptions with predefined RTOs and RPOs.
- All staff must be trained on their roles during business continuity and disaster recovery scenarios.
- Regular testing of BC/DR plans must be conducted to ensure readiness.
- Communication with patients and stakeholders must be a priority during disruptions to maintain trust.

# Chapter 4

# Mapping Business Objectives to Security Goals

Cybersecurity plays an important role in helping MediCare Hospital achieve its mission by making sure that patient care processes run safely, sensitive patient and hospital information stays protected, and essential systems like Electronic Health Records (EHR), ICU/ER monitors, and login systems are always working. Connecting the hospital's business goals to security goals helps administrators match security efforts with the hospital's main priorities, handle risks properly, and follow healthcare rules such as HIPAA and local privacy laws. This approach makes sure that all cybersecurity efforts at MediCare Hospital have a clear purpose, focus on protecting the most important resources, and directly help the hospital provide safe and reliable healthcare. By looking at how each security goal affects Confidentiality (keeping data private), Integrity (keeping data accurate), and Availability (keeping systems working), decision-makers can decide what to do first and use resources in the best way, as shown in in Table 5.10

Table 4.1: Mapping of Business Objectives to Security Goals and CIA Impact

| **Business Objective** | **Security Goal** | **CIA Impact** |
|---|---|---|
| Protect patient data | Encrypt all EHR records and lab results | Confidentiality |

*Continued on next page*

| Business Objective | Security Goal | CIA Impact |
|---|---|---|
| Ensure availability of critical hospital systems (ICU/ER monitors, appointment scheduling) | Use backup servers, data backups, and automatic failover systems | Availability |
| Keep medication administration records accurate and unchanged | Apply access control, audit logging, and digital signatures | Integrity |
| Protect financial transactions and billing information | Use secure payment gateways and transaction monitoring | Confidentiality, Integrity |
| Comply with healthcare regulations (HIPAA, local privacy laws) | Implement data retention policies, regular audits, and secure access controls | Confidentiality, Integrity, Availability |

# Summary of Security Measures

- **Protect patient data:** Encrypting EHR and lab records ensures confidentiality and prevents unauthorized access, maintaining trust and compliance with privacy regulations.
- **Ensure availability of hospital systems:** Redundant servers, backups, and failover mechanisms guarantee that critical systems remain operational, reducing downtime in ICU, ER, and other patient care areas.
- **Maintain integrity of medication records:** Access controls, audit logs, and digital signatures prevent unauthorized modifications, ensuring patient safety and accurate treatment.
- **Safeguard financial transactions:** Secure payment gateways and transaction monitoring protect the hospital and patients from fraud while maintaining data confidentiality and integrity.
- **Comply with healthcare regulations:** Data retention policies and regular audits

ensure MediCare Hospital meets legal requirements while maintaining the CIA triad for all critical systems.

By clearly connecting MediCare Hospital's business goals with security goals, the hospital management can decide which cybersecurity actions are most important, handle risks more effectively, and make sure hospital operations continue smoothly while keeping patients safe.

# Chapter 5

# Security Program Design

## 5.1 Program goals

The purpose of this Security Program Design is to establish a comprehensive, integrated, and regulatory-compliant framework to protect the hospital's patients, staff, visitors, physical assets, and Protected Health Information (PHI). The program is built upon the principles of layered defense, risk-based decision-making, and mandatory compliance with U.S. federal regulations, notably the HIPAA Security Rule and the CMS Conditions of Participation (CoPs). The program integrates Administrative, Physical, and Technical safeguards to create a holistic security posture

## 5.2 Governance Structure for Cybersecurity

Governance Structure for Cybersecurity refers to the framework and organizational hierarchy that establishes roles, responsibilities, and processes for managing an organization's cybersecurity risks. It ensures that cybersecurity practices align with the organization's objectives and regulatory requirements, fostering a culture of security across all levels of the organization. [6]

### 5.2.1 CISO Role

The Chief Information Security Officer (CISO) in a hospital is a key executive responsible for overseeing the cybersecurity strategy and ensuring the protection of sensitive patient data. The CISO's primary responsibilities include:

- **Strategic Leadership:** Develop and implement a comprehensive cybersecurity strategy that aligns with the hospital's overall mission and goals, emphasizing patient safety

and data integrity.

- **Policy Development:** Create and enforce security policies and procedures that govern the use of information technology and protect sensitive health information.
- **Risk Management:** Conduct risk assessments to identify vulnerabilities and potential threats, and implement appropriate controls to mitigate these risks.
- **Incident Response Planning:** Lead the development and execution of incident response plans to effectively handle security breaches and mitigate their impact.
- **Training and Awareness:** Promote a culture of cybersecurity awareness within the hospital, providing training and resources for all employees to recognize and respond to security threats.
- **Compliance Management:** Ensure adherence to regulatory standards and frameworks relevant to healthcare, such as HIPAA (Health Insurance Portability and Accountability Act) and NIST Cybersecurity Framework.

## Security Team Responsibilities

The security team, led by the CISO, plays a critical role in maintaining the hospital's cybersecurity posture. Their key responsibilities include:

- **Monitoring and Detection:** Continuously monitor the hospital's IT infrastructure for any signs of security incidents or breaches using security information and event management (SIEM) systems.
- **Vulnerability Management:** Conduct regular vulnerability assessments and penetration testing to identify weaknesses in systems, followed by timely remediation actions.
- **Access Control Management:** Implement and manage access controls to ensure that only authorized personnel can access sensitive data and systems.
- **Incident Handling:** Respond to and investigate security incidents, documenting findings and coordinating recovery efforts to restore normal operations.
- **Security Awareness Programs:** Develop and deliver training programs aimed at educating hospital staff about best practices in cybersecurity, phishing awareness, and safe handling of patient data.

## Reporting Hierarchy

The reporting hierarchy within the hospital's cybersecurity framework is designed to ensure effectiveness and accountability:

- **CISO:** Reports directly to the CEO or the hospital board, providing updates on the overall cybersecurity posture, incidents, and strategic initiatives.
- **Security Team Lead:** Reports to the CISO and is responsible for day-to-day operations of the security team, including incident response and team performance.
- **Security Analysts/Technicians:** Report to the Security Team Lead, working on monitoring, incident remediation, vulnerability assessments, and user training.
- **Department Heads:** Interact with the security team to ensure their departments comply with security policies and practices while reporting any security concerns related to their operations.

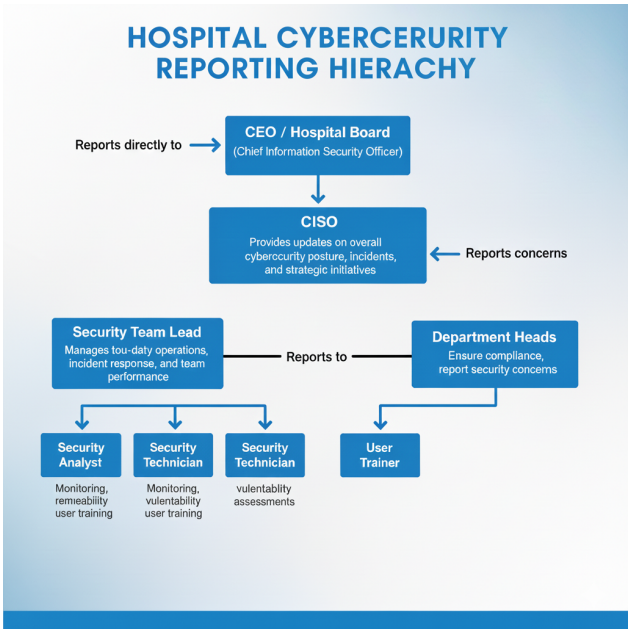



Figure 5.1: Cybersecurity reporting hierarchy in the hospital.

## Continuous Improvement and Audits

Continuous improvement is critical in maintaining a robust cybersecurity posture. Key elements include:

- **Regular Audits:** Conduct periodic internal and external audits of cybersecurity practices to assess compliance with organizational policies and external regulations. This also involves reviewing incident reports and response effectiveness.
- **Performance Metrics:** Establish and track key performance indicators (KPIs) related to security incidents, response times, and employee training effectiveness to identify areas for improvement.
- **Feedback Mechanisms:** Create channels for employees to provide feedback on security policies and procedures, facilitating a proactive approach to identify gaps or areas needing enhancement.
- **Continuous Training:** Implement ongoing training programs that adapt to evolving threats, ensuring that staff remain informed and prepared for new challenges in the cybersecurity landscape.
- **Learning from Incidents:** After every security incident, conduct a thorough post-incident review to analyze response effectiveness and update policies and training to address findings.

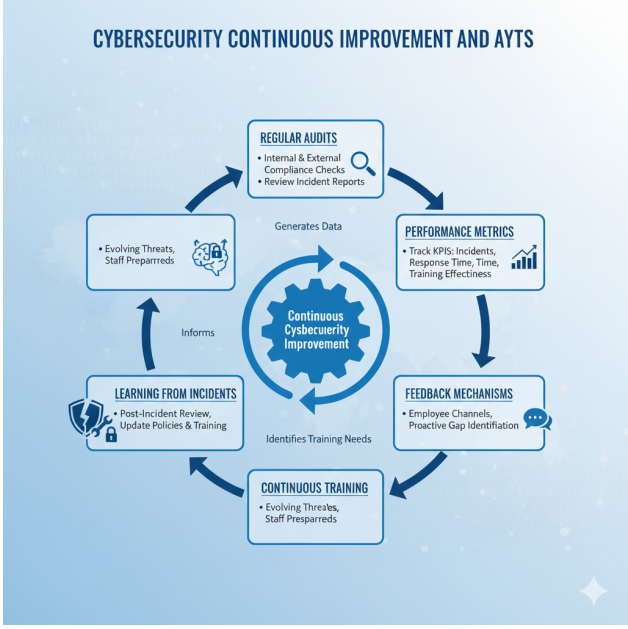



Figure 5.2: Cybersecurity Continuous Improvement and Audit Cycle (PDCA).

## 5.3 NIST Cybersecurity Framework Alignment

The NIST Cybersecurity Framework is a set of principles and guidelines designed to help organizations, such as hospitals, manage and enhance their cybersecurity posture. This framework focuses on improving institutional readiness to face cybersecurity threats through five core functions: Identify, Protect, Detect, Respond, and Recover. [7]

### 5.3.1 Purpose

To provide a framework that assists hospitals in protecting sensitive patient information and healthcare systems from cybersecurity threats through clear organization of procedures and strategies.

### 5.3.2 Objectives

- **Improving Risk Management:** Conduct a comprehensive assessment of all potential risks facing the hospital.
  - Example:Hospitals can perform regular risk assessments using tools like risk matrices to identify vulnerabilities in their electronic health record (EHR) systems, ensuring they address the most critical threats first.

- **Enhancing Protection:** Implement preventive measures to safeguard data and maintain the integrity of systems.
  - Example: Utilising strong password policies and two-factor authentication for accessing sensitive patient records can significantly reduce unauthorized access.

- **Early Detection of Incidents:** Enable technology and personnel to identify security events in a timely manner.
  - Example: Deploying Security Information and Event Management (SIEM) systems that analyze logs from various sources can help IT staff identify and respond to abnormal activities quickly.

- **Effective Response:** Develop rapid and comprehensive response strategies and plans for incidents.
  - Example: Creating an incident response team with defined roles and responsibilities can ensure swift action during a data breach, including communication plans for notifying affected patients.

- **Rapid Recovery:** Establish clear plans for recovering vital data and operations following incidents.
  - Example: Implementing regular data backups and a disaster recovery plan that includes failover protocols can enable hospitals to restore services within hours after a cyber incident.

### 5.3.3 Alignment of Functions with the NIST CSF

| Function | Description | Key Activities |
|---|---|---|
| **Identify** | Understanding cybersecurity risks faced by the hospital and maintaining an asset inventory. | Risk assessments, asset inventory development, risk management strategies. |
| **Protect** | Implementing safeguards to protect sensitive patient data and healthcare operations. | Access controls, data encryption, staff training. |
| **Detect** | Continuous monitoring for identifying anomalies and potential breaches in the hospital's IT systems. | Intrusion detection systems, log analysis, regular security evaluations. |
| **Respond** | Actions taken to address detected incidents and mitigate impact. | Incident response plans, IRT readiness, communication strategies. |
| **Recover** | Processes for restoring systems and data after an incident. | Data backup strategies, business continuity planning, post-incident analysis. |

Table 5.1: Alignment of NIST Cybersecurity Functions with Hospital Operations

## 5.4 Implementation Strategy

### 5.4.1 Technical Security and Training

This section outlines the measures to protect Electronic Protected Health Information (ePHI) from cyber threats and unauthorized logical access and it is divided into Three sections, the Access Control (Logical) section, details are shown in the Table 5.2, the Network and Endpoint Security section, also shown in the Table 5.3, Finally Security Training and Awareness shown in the Table 5.4

| **Safeguard** | **Description** | **Compliance/Standard** |
|---|---|---|
| Unique User ID | Every user must have a unique identifier for accountability and audit trails | HIPAA Technical Safeguard[8] |
| Multi-Factor Authentication (MFA) | Mandatory MFA for all remote access, administrative access to ePHI systems, and access to cloud services | Best Practice/Industry Standard |
| Role-Based Access Control (RBAC) | Access to Electronic Health Records (EHR) and other systems is granted based on the principle of **Minimum Necessary Access** determined by the user's job role | HIPAA Privacy Rule/Technical Safeguard[8] |

*Continued on next page*

| Safeguard | Description | Compliance/Standard |
|---|---|---|
| Emergency Access | Establish a documented **"Break-Glass"** procedure for granting emergency access to systems when normal credentials fail. Requires comprehensive auditing | HIPAA Technical Safeguard[8] |

Table 5.2: Access Control (Logical)

| System/Protocol | Description | Rationale |
|---|---|---|
| Network Segmentation | Isolate critical systems (EHR servers, PACS, Biomedical Devices) onto separate network segments (VLANs) to limit the lateral spread of malware or ransomware | Containment and Risk Reduction |
| Encryption | Mandatory encryption of all ePHI transmitted over electronic networks (using TLS/SSL) and encryption of ePHI stored on all mobile devices and backup media | HIPAA Technical Safeguard [8] |

*Continued on next page*

| System/Protocol | Description | Rationale |
|---|---|---|
| Patch Management | Implement an aggressive patch and vulnerability management program for operating systems, applications, and especially medical IoT devices | Addressing known vulnerabilities proactively |
| Email Security | Advanced threat protection (ATP), secure email gateways, and mandatory encryption for emails containing PHI sent outside the hospital network | Prevention of phishing and data leakage |

Table 5.3: Network and Endpoint Security

| Training Focus | Frequency/Requirement | Content |
|---|---|---|
| New Hire Orientation | Mandatory before access is granted | HIPAA Privacy/Security[8] essentials, Code of Conduct, emergency codes, de-escalation techniques |
| Annual Refresher | Mandatory annual training for all staff | Policy changes, simulated phishing/social engineering exercises, review of high-risk areas |

*Continued on next page*

| Training Focus | Frequency/Requirement | Content |
|---|---|---|
| Role-Based Training | Specialized training for high-risk roles (e.g., Pharmacy staff, IT administrators, Emergency Department personnel) | Safe handling of controlled substances, Active Shooter/Mass Casualty incident (MCI) response, system administration security |
| Workplace Violence | Mandatory for all staff and security personnel | Crisis intervention and verbal de-escalation techniques (required by CMS), recognizing behavioral triggers |

Table 5.4: Security Training Requirements and Focus Areas

### 5.4.2 Physical Security and Safety

This section focuses on protecting the hospital facility, patients, and staff from physical threats and unauthorized access and it is divided into three sections Access Control and Perimeter Security details are shown in the Table 5.5, and Surveillance and Monitoring section which also its details shown in Table 5.3 and finally Security Personnel and Patrols section.

| Area/Asset | Control Method | Requirement/Guideline |
|---|---|---|
| External Perimeter | Clearly defined boundaries, adequate lighting (Crime Prevention Through Environmental Design - CPTED), and controlled vehicle access (e.g., bollards, gate access) | IAHSS Design Guidelines [9], Best Practice |

*Continued on next page*

| Area/Asset | Control Method | Requirement/Guideline |
|---|---|---|
| Main Entrances | Staffed security desk (24/7), visitor management system (ID scanning, temporary badge issuance, defined access zones), and after-hours lockdown protocols | Security, Accountability, and Visitor Management |
| Restricted Areas (High-Risk) | NICU/Labor & Delivery, Pharmacy, Data Center, Behavioral Health Units. Require multi-factor authentication (e.g., Proximity Badge + Biometric/PIN) and door interlocking (mantraps) | HIPAA Physical Safeguards [8], IAHSS Guidelines [9] |
| General Patient Areas | Role-Based Access Control (RBAC) via electronic key cards to limit unauthorized entry to patient wings, staff break rooms, and non-public corridors | Role-Based Security |
| Workstation Security | Implement physical locks or cable tethers for all fixed workstations and mobile computers (WoWs). Automatic log-off after inactivity | HIPAA Physical Safeguards[8] |

Table 5.5: Access Control and Perimeter Security

| System | Deployment Strategy | Purpose |
|---|---|---|
| CCTV System | High-definition digital cameras with sufficient storage (90+ days). Coverage in all public areas, entrances, hallways, parking garages, and high-risk internal zones | Deterrence, forensic evidence, real-time monitoring of suspicious activity |
| Video Analytics | Use AI-powered detection for anomalies: loitering in restricted areas, objects left unattended, and unauthorized tailgating at access points | Proactive threat detection and alert generation |
| Panic/Duress Alarms | Install silent duress alarms in strategic locations: ED triage, Pharmacy counters, Behavioral Health staff stations, and administrative offices dealing with finance | Rapid response activation for staff under threat |

Table 5.6: Surveillance and Monitoring

Security Personnel and Patrols

- Security Presence: Deploy visible, uniformed security personnel 24/7/365, focusing resources on the Emergency Department (ED), behavioral health units, and main entrances.
- Patrols: Conduct regular, documented internal and external patrols with varying routes and timings to prevent predictability.

- Specialized Training: All security staff must be certified in verbal de-escalation, use of force (if applicable), first aid, and fire suppression, in addition to HIPAA compliance.

## 5.5 Risk Management and Assessment

### 5.5.1 Scope and Classified Assets (The Attack Surface)

The hospital's critical assets have been formally classified in details 2.1 based on their sensitivity and importance to patient care and operational continuity. Threats to Highly Critical and Highly Sensitive assets must be prioritized.

### 5.5.2 Threat Agents and Motivation

This section outlines the potential adversaries both external (cybercriminals) and internal (malicious staff or careless users) who pose a risk to the hospital. Understanding their motivations helps tailor protective measures and the details are represented in table **??**

| **Threat Agent** | **Motivation** | **Risk Level** | **Primary Targets** |
|---|---|---|---|
| Cyber-Criminals/Organized Groups (External) | Financial gain (Ransomware, data sale), extortion | High | Highly Sensitive Data (ePHI), Highly Critical Systems (EHR, Network) |
| Disgruntled/Malicious Insider (Internal) | Revenge, financial gain (theft of drugs/supplies), or curiosity/snooping | Critical | Highly Sensitive Data (ePHI), Controlled Substances (Pharmacy), Proprietary Research |

*Continued on next page*

| Threat Agent | Motivation | Risk Level | Primary Targets |
|---|---|---|---|
| Careless/Uninformed Staff (Internal) | Human error (losing devices, falling for phishing, misconfigurations), bypassing security for convenience | High | Workstations, Unencrypted Data, Network Segments |
| Vandals/Aggressive Visitors (External/Physical) | Emotional distress, frustration, mental health crisis, theft | Critical | Highly Critical Human Resources (Staff), Physical Facilities (ED), Public Areas |
| State-Sponsored Actors (External/Advanced) | Espionage, intellectual property theft (medical research), critical infrastructure sabotage | Moderate | Research Data, OT Systems, Highly Critical IT Infrastructure |

Table 5.7: Threat Agents and Motivation

### 5.5.3 Critical Vulnerabilities and Entry Points

This section highlights the specific weaknesses and exploitable entry points—spanning technical systems, administrative processes, and physical access controls—that threat agents are most likely to targe. So, the following table **??** represent high-priority vulnerabilities that threat agents will seek to exploit:

| Vulnerability Type | Description | Remediation Focus |
|---|---|---|
| Physical (Human) | Tailgating/Piggybacking: Unauthorized personnel follow an authorized person through a secured door | Anti-passback systems, mandatory staff challenge protocols, security staffing at key doors |
| Physical (Infrastructure) | Propped Doors: Staff prop open secure doors (e.g., IT closets, post-partum unit doors) for convenience | Integrated door alarms, immediate security response for door-forced-open alerts |
| Technical (Software) | Unpatched Medical Devices (IoMT): Critical Medical Devices running outdated, vulnerable operating systems (e.g., Windows 7) | Comprehensive asset inventory, network segmentation, and vendor-coordinated patching plan |
| Technical (People) | Phishing/Social Engineering: Staff revealing passwords or clicking malicious links due to distraction or lack of training | Continuous, simulated phishing exercises and mandatory annual training |
| Administrative (Process) | Lack of Offboarding: Terminated employee/contractor credentials (physical badges, VPN access) are not immediately revoked upon separation | Integrated HR/Security system for immediate access revocation |

Table 5.8: Critical Vulnerabilities and Entry Points

### 5.5.4 Risk Assessment Matrix

To ensure focused resource allocation and maintain a defense-in-depth security posture, this matrix systematically quantifies the risk associated with each identified threat. By assigning scores to both Likelihood (how often an event may occur) and Impact (the severity of the resulting consequences), the hospital can calculate a verifiable Risk Score (L x I). Scenarios scoring the highest are designated as immediate mitigation priorities, guiding executive-level decisions on security investment and control implementation.

| **Threat Scenario (STRIDE)** | **Asset Impacted** | **Likelihood (L:1-5)** | **Impact (I:1-5)** | **Risk Score (LxI)** | **Mitigation Priority** |
|---|---|---|---|---|---|
| DoS: EHR System Shutdown (Ransomware) | Hospital Software Systems (Highly Critical) | Frequent Attack (4)(Vector) | Catastrophic (5)(Patient Harm, Fines) | 20 | **IMMEDIATE** (BCDR, Network Isolation, MFA) |
| Tampering: Remote Dose Manipulation (IoMT) | Medical Equipment (Critical) | Requires High (2)(Skill/Access) | Catastrophic (5)(Loss of Life) | 10 | **HIGH** (Segmentation, Device Hardening) |
| Information Disclosure: Phishing leading to ePHI Theft | Patient Information (Highly Sensitive) | High Staff Error(4) (Rate) | Major(4) (Fines, Reputational Damage) | 16 | **IMMEDIATE** (Training, MFA, DLP) |
| Spoofing: Stolen Badge Access to Pharmacy/Data Center | Physical Facilities/ Controlled Substances | Moderate Access (3)(Control Gaps) | Moderate(3) (Theft, Sabotage) | 9 | **MEDIUM** (Anti-passback, Dual-Factor Physical Access) |

*Continued on next page*

| **Threat Scenario (STRIDE)** | **Asset Impacted** | **Likelihood (L:1-5)** | **Impact (I:1-5)** | **Risk Score (LxI)** | **Mitigation Priority** |
|---|---|---|---|---|---|
| Elevation of Privilege: Contractor Gaining Root Access | IT Infrastructure (Highly Critical) | Unpatched Systems/Least Privilege(3) | Major (4)(Network Control) | 12 | **HIGH** (Patching, RBAC, PAM) |
| Repudiation: Unauthorized Chart Access (Insider) | Patient Information (Highly Sensitive) | Insider Threat(3) | Moderate (3)(HIPAA Violation, HR Issue) | 9 | **MEDIUM** (Audit Logging, Unique IDs) |
| Physical DoS/Assault: Workplace Violence/ED Barricading | Human Resources (Highly Critical) /Physical Facilities | Occasional (3)(Incidents) | Catastrophic (5) (Injury, DoS to ED) | 15 | **IMMEDIATE** (Security Presence, De-escalation Training) |

Table 5.9: Risk Assessment Matrix

## 5.6 Business Continuity and Disaster Recovery Plan

The Business Continuity and Disaster Recovery (BC/DR) Plan for MediCare Hospital ensures that essential healthcare services remain operational during disruptive events such as cyberattacks, system failures, natural disasters, power outages, or medical equipment malfunctions. As a healthcare institution relying heavily on Electronic Health Records (EHR), diagnostic systems, and patient-monitoring equipment, ensuring continuous availability is critical to patient safety and regulatory compliance.

### 5.6.1 Business Impact Analysis (BIA)

The Business Impact Analysis identifies essential hospital functions, evaluates potential consequences of disruptions, and establishes appropriate Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) details are provided in the table 5.10.

| Critical Function | Impact of Disruption | RTO | RPO |
|---|---|---|---|
| Electronic Health Records (EHR) | Inability to access patient histories, labs, medications; delays diagnosis and treatment | 1 hour | 15 minutes |
| ICU/ER Monitoring Systems | Life-threatening delays in patient monitoring and vital signs tracking | Immediate | Zero data loss |
| Radiology / PACS Systems | Delays in imaging results needed for urgent care | 4 hours | 1 hour |
| Pharmacy Systems | Medication dispensing delays, risk to patient treatment schedules | 2 hours | 30 minutes |
| Laboratory Information System (LIS) | Slowed diagnostic workflows impacting critical treatment | 4 hours | 1 hour |
| Billing & Financial Systems | Financial interruptions; does not directly affect patient safety | 48 hours | 24 hours |

Table 5.10: Critical Functions, Impact, and Recovery Objectives

### 5.6.2 Backup strategies

## Backup Types and Frequencies

- **Daily Incremental Backups**: For EHR, PACS, pharmacy, and lab systems.

- **Weekly Full Backups**: Entire system snapshot including configurations.
- **Real-Time Replication**: For high-priority clinical databases.

### Storage Strategy

- On-premise secure storage in the hospital's data center.
- Encrypted cloud/offsite backups for disaster scenarios.
- Immutable storage for ransomware-resistant data protection.

### Backup Testing

- Quarterly restore tests to validate data integrity.
- Annual full-scale disaster simulation to test system-wide recoverability.

### Security Measures

- AES-256 encryption for backup data.
- Access restricted using Role-Based Access Control (RBAC) with MFA.
- Continuous monitoring for backup failures or tampering.

### 5.6.3 Disaster Recovery Procedures

### 1. Incident Detection and Activation

- IT Security identifies a disruption (cyberattack, outage, hardware failure).
- CIO activates the Disaster Recovery Team (DRT).
- Staff notified through SMS, internal alerts, or emergency communication channels.

### 2. Containment and Assessment

- Isolate affected systems when a cyberattack is suspected.
- Assess scope, downtime expectations, and affected departments.
- Follow prioritization defined by RTO/RPO.

## 3. System Recovery Steps

**For Critical Clinical Systems:**

- Switch to the backup EHR server or cloud replica.
- Restore databases from the latest backup or replication.
- Reconnect patient monitoring systems using failover network segments.
- Verify data integrity before resuming care operations.

**For Diagnostic Systems (PACS/LIS/RIS):**

- Recover application servers and restore imaging archives.
- Validate compatibility with medical devices.

**For Administrative Systems:**

- Restore billing, HR, scheduling, and communication platforms.
- Execute recovery only after clinical systems are stabilized.

## 4. Communication Procedures

- Provide updates to department heads every 30–60 minutes.
- Notify regulators, vendors, and partner organizations when required.
- All public statements handled by Communications Office.

## 5. Verification and Return to Normal Operations

- DRT validates system stability, performance, and completeness of recovered data.
- Primary data center operations return once secure.
- Document incident details, recovery steps, and lessons learned.

## 5.7 Evaluation Framework

This section presents the Cybersecurity Maturity Assessment and Evaluation for MediCare Hospital program, using a six-level capability model to evaluate the organization's preparedness across key security domains. Each domain—such as leadership, controls and plans, employee awareness, business continuity, and incident response—was assessed to determine how well current practices align with industry standards and regulatory expectations. Overall, the results shown in Table 5.11 which indicate that MediCare Hospital has achieved moderate to strong maturity in several areas, with especially high performance in business continuity, crisis communications, and recovery planning.

| **Domain** | **Non-Existent** (1) | **Initial/ Ad-Hoc** (2) | **Repeatable but Intuitive** (3) | **Defined** (4) | **Managed and Measurable** (5) | **Optimized** (6) |
|---|---|---|---|---|---|---|
| Organizational Context | | | | 4.10 | | |
| Leadership | | | 3.90 | | | |
| Controls & Plans | | | | 4.30 | | |
| Employee Awareness & Capabilities | | | 3.85 | | | |
| Program Documentation | | | 3.70 | | | |
| BIA & Risk Assessment | | | | 4.20 | | |
| Business Continuity Strategies | | | | 4.50 | | |
| Incident & Crisis Communications | | | | | 5.00 | |
| Crisis Communications | | | | | 5.40 | |
| Business Continuity & Recovery | | | | 4.60 | | |
| Exercising & Testing | | | 3.95 | | | |
| Evaluation & Improvement | | | | 4.00 | | |
| | | | | | **TOTAL MATURITY SCORE** | **4.36** |

Table 5.11: Cybersecurity Maturity Assessment Table

# Chapter 6

# Recommendations and Future Improvements

To strengthen MediCare Hospital's cybersecurity posture and ensure long-term resilience, the following recommendations and future improvements are proposed. These enhancements focus on advancing technology adoption, improving security culture, and aligning with emerging best practices in healthcare cybersecurity.

1. **Implement a Zero Trust Architecture (ZTA)**
   MediCare Hospital should gradually transition to a Zero Trust model where no device, user, or network segment is trusted by default. This includes continuous authentication, micro-segmentation, identity-based access, and strong device compliance checks. Zero Trust will significantly enhance protection against insider threats, lateral movement, and ransomware attacks.

2. **Expand Network Segmentation and Medical Device Isolation**
   As medical IoT devices (ventilators, pumps, monitors) continue to grow, isolating them into dedicated VLANs will limit the impact of malware or unauthorized access. Integrating AI-based network monitoring tools can further identify anomalous device behavior in real time.

3. **Deploy Advanced Endpoint Detection and Response (EDR)**
   Traditional antivirus is no longer sufficient for modern threats. Implementing EDR solutions with threat hunting, automated incident response, and behavioral analytics will enable faster detection and containment of cyberattacks across workstations, servers, and mobile devices.

4. **Strengthen Employee Cybersecurity Awareness Programs**
   Human error remains a primary source of security incidents. The hospital should introduce:

   - Monthly learning lessons
   - Phishing simulations
   - Role-based training for high-risk departments
   - Mandatory refreshers for new threats

   Improving staff awareness will significantly reduce phishing, social engineering, and data handling mistakes.

5. **Enhance Vendor and Third-Party Risk Management**
   Given the large number of medical equipment vendors and software providers, the hospital should implement a formal Vendor Risk Management (VRM) program that includes:

   - Security assessments before onboarding
   - Continuous monitoring of vendor access
   - Enforcement of least privilege
   - Annual security compliance certifications

6. **Adopt Cloud-Based Backup and Disaster Recovery Solutions**
   To improve resilience against ransomware and outages, MediCare Hospital should migrate critical backups to secure, encrypted, offsite cloud environments. Automated backup validation and periodic disaster recovery simulations will further ensure quick restoration of medical services.

7. **Implement Privileged Access Management (PAM)**
   Privileged accounts pose significant risk if compromised. A PAM solution can automate:

   - Just-in-time (JIT) access
   - Session recording
   - Password vaulting
   - Automatic credential rotation

   This will reduce the attack surface and prevent misuse of administrative privileges.

8. **Integrate AI-Powered Threat Intelligence Systems**
   AI and machine learning can improve the hospital's ability to detect emerging threats by:

   - Analyzing network traffic
   - Predicting attack patterns
   - Identifying compromised accounts
   - Correlating SIEM alerts

   This will reduce Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR).

9. **Improve Physical Security Measures**
   Recommendations include:

   - Upgraded CCTV with AI anomaly detection
   - Anti-tailgating door systems
   - Biometric authentication for critical zones
   - Panic alarms in high-risk departments

   These improvements strengthen safety for staff, patients, and assets.

10. **Develop a Continuous Audit and Compliance Program**
    Regular internal audits, gap assessments, and compliance checks should be conducted to ensure alignment with HIPAA, NIST CSF, and national healthcare regulations. Audit results should guide future policy updates and staff training.

# Chapter 7

# Conclusion

In conclusion, this project highlights the importance of strong cybersecurity operations across all sectors. By identifying and classifying information, hardware, software, physical, and human assets, it provides a clear understanding of what needs protection and why these assets are vital for organizational continuity. Effective asset management strengthens security, supports daily operations, and builds trust among users and stakeholders. Ultimately, cybersecurity is a universal necessity whether in healthcare, education, business, or government ensuring data protection, service reliability, and resilience against evolving threats.

# References


[1] C. University, "Data classification," https://www.clemson.edu/ccit/cybersecurity/policy/data-classification.html, 2025, accessed: December 6, 2025.

[2] A. Faridoon and M. T. Kechadi, "Healthcare data governance, privacy, and security: A conceptual framework," *arXiv preprint arXiv:2403.17648*, 2024. [Online]. Available: https://arxiv.org/pdf/2403.17648

[3] N. C. A. (NCA), "Patch management policy template," https://cdn.nca.gov.sa/api/public/cms/files/ba218b18-e7f1-4974-bbe1-1eeb592c810c_POLICY_Patch_Management_Template_en-.pdf, 2024, accessed: 2025-12-06.

[4] ——, "Incident response policy," https://cdn.nca.gov.sa/api/public/cms/files/ba218b18-e7f1-4974-bbe1-1eeb592c810c_Incident_Response_Policy.pdf, 2024, accessed: 2025-12-06.

[5] ——, "Business continuity policy and disaster recovery (bc/dr) policy," https://cdn.nca.gov.sa/api/public/cms/files/ba218b18-e7f1-4974-bbe1-1eeb592c810c_Business_Continuity_Policy_and_Disaster_Recovery_Policy.pdf, 2024, accessed: 2025-12-06.

[6] OIC-CERT, "Cyber-security governance framework," https://www.oic-cert.org/en/download/Egypt_OIC%20CERT%20Cyber-Security%20Governance%20Framework%20v1.pdf, May 2024, accessed: 2025-12-06.

[7] N. I. of Standards and Technology, "Nist cybersecurity framework 2.0," https://www.nist.gov/cyberframework/CSF2.0, 2024, accessed: 2025-12-06.

[8] U.S. Department of Health and Human Services (HHS), "Hipaa security rule," https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html, 2013, 45 CFR s164.310.

[9] International Association for Healthcare Security and Safety (IAHSS), *Security Design Guidelines for Healthcare Facilities*, 3rd ed. Glendale Heights, IL, USA: IAHSS Foundation, 2020.